

EU AI ACT PACK

PII Handling

Data-protection measures

Lexy AI Hiring Platform · Generated 2026-07-20

Factual description of the system as built. Not legal advice; assumptions flagged for counsel.

Audience: Lexy engineers, on-call, and anyone fielding a GDPR / CCPA request. This is the *internal* runbook. The customer-facing equivalents live at:

- `artifacts/lexy-site/legal/dpa.md` — Data Processing Agreement
- `artifacts/lexy-site/src/pages/privacy.tsx` — public Privacy Policy
- `artifacts/lexy-site/src/pages/terms.tsx` — Terms of Service

If you’re answering a regulator, point them at those. If you’re *implementing* the response, read this.

1. Personal data inventory

Every column below is treated as Personal Data under GDPR Art. 4(1) / CCPA §1798.140(o). The erasure cascade in `routes/dnc.ts` and `routes/career-profile.ts` covers all of these — if you add a new PII column, you **MUST** also add it to both cascades and to the `/portal/me/export` endpoint.

1.1 Recruiter-side (`users` table)

Field	Source	Purpose	Retention
email	signup	login + notifications	until account deletion
name	signup	UI display	until account deletion
passwordHash	derived (bcrypt-10)	auth	until account deletion
avatarUrl	upload	UI	until account deletion
timezone	signup / profile	scheduling, digest delivery	until account deletion

Recruiter accounts are not currently self-service deletable — they go through support. See §6 for the rationale.

1.2 Candidate-side (`candidates` table — primary subject)

Field	Source	Purpose	Notes
firstName/lastName	recruiter import OR self-signup	identification	erased to "[Erased]"
email	same	outreach, login	erased to <code>erased+<id>@deleted.invalid</code>
phone	recruiter / resume parse	optional outreach	erased to <code>NULL</code>
location	recruiter / resume parse	matching	erased to <code>NULL</code>
linkedinUrl / githubUrl	recruiter / sourcing	enrichment	erased to <code>NULL</code>
currentTitle / currentCompany	recruiter / resume / PDL	matching	erased to <code>NULL</code>
skills	resume parse / AI extraction	matching	erased to <code>[]</code>
resumeUrl	upload → S3	screening	S3 object DELETED on erasure

1.3 Candidate-side adjacencies

Table	What it holds	On erasure
candidate_career_profiles	self-described goals, salary, bio	hard delete (both cascades)
candidate_job_intelligence	AI-generated job-fit notes (PII-bearing)	hard delete
outreach_messages	full message bodies (PII)	hard delete
outreach_enrollments	recipient name + email	anonymised, status=stopped
nurture_pool	recipient name + email	anonymised, status=stopped
applications	notes field can contain PII	notes overwritten with audit stub, stage→rejected
interview_sessions	answers, recording URL, proctoring events	hard delete + S3 purge
interview_summaries	AI evaluation of answers	hard delete
interview_schedules	scheduled times	hard delete
candidate_action_events	clicks, opens	hard delete
candidate_skill_scores	per-skill AI scores	hard delete
verification_records	identity / video proctoring artifacts	hard delete
communication_events	sent emails (subject + body)	retained (see §6)
audit_logs	actor-subject events	retained (see §6)

1.4 Storage outside Postgres

Store	What lives there	Retention
AWS S3	resume bytes, interview recordings, avatars	deleted on candidate erasure (best-effort)
pino stdout	request logs (redacted: authorization , cookie , etc.)	ephemeral per container; aggregate per host policy
Stripe	recruiter billing only — name, email, payment method	per Stripe retention policy

2. Sub-processors

Every external service that receives Personal Data must appear in this table. The published Data Processing Agreement at [artifacts/lexy-site/legal/dpa.md](#) **Annex C** is the customer-facing list. Right now the two are out of sync (see §2.1) — reconcile before the first signed DPA goes out.

2.1 Actual sub-processors (what the code does today)

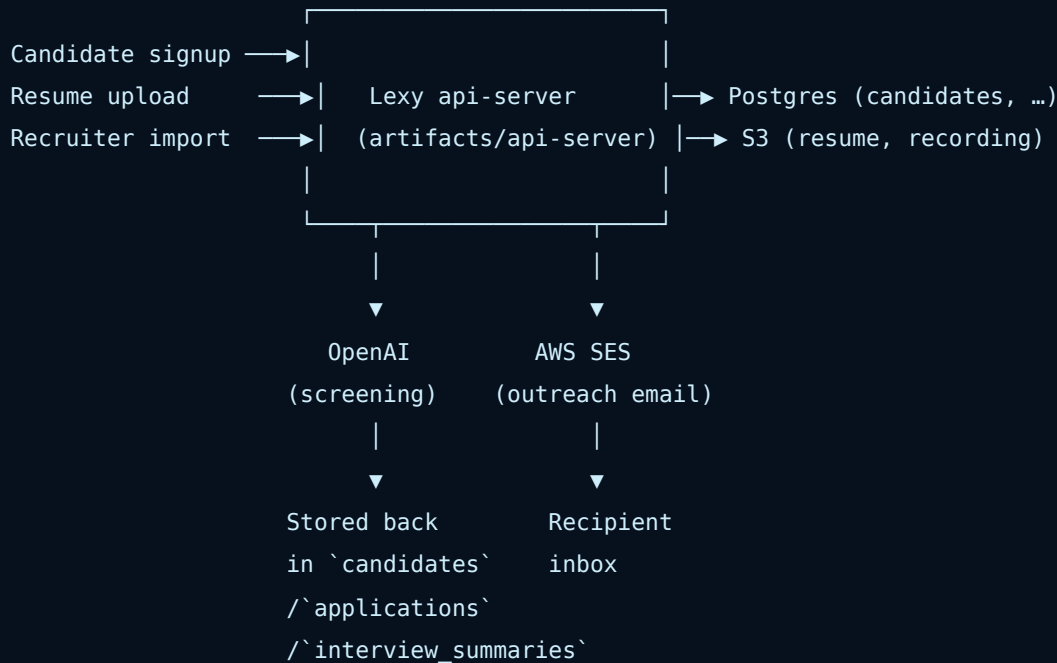
Sub-processor	Data sent	Purpose	Where in code
OpenAI (gpt-4o)	resume text, candidate skills, interview answers, recruiter prompts	screening, summarization, outreach generation	lib/ai.ts , routes/interviews.ts , routes/career-profile.ts , lib/outreach-engine.ts , lib/anti-ghost-engine.ts
AWS S3 (eu-west-*)	resume files, interview recordings, avatars	object storage	lib/s3.ts
AWS SES	recipient email + name + body	transactional email	lib/email.ts (called from many routes)
Stripe	recruiter name, email, payment method	subscription billing	routes/billing.ts , routes/public.ts , lib/plans.ts
People Data Labs	candidate name / company / location queries	external sourcing	lib/external-sourcing.ts (gated on PDL_API_KEY)
EnrichLayer	LinkedIn URL → profile enrichment	external sourcing	lib/external-sourcing.ts (gated on ENRICH_LAYER_API_KEY)
SerpAPI	name / company search query string	LinkedIn URL discovery	lib/external-sourcing.ts (gated on SERP_API_KEY)
Azure STT	interview audio bytes	speech-to-text transcription	routes/interviews.ts
BetterStack	scheduler heartbeats (NO PII)	uptime monitoring	lib/heartbeat.ts (opt-in via env)

2.2 Drift vs. DPA Annex C (must reconcile before launch)

Service	Annex C says...	Code says...	Action
Transactional email	Postmark / SendGrid	AWS SES	Update Annex C to “AWS SES”
Observability	Sentry / Datadog	none (pino → stdout)	Either remove from Annex C, or wire one up and keep it
OpenAI	(not listed)	gpt-4o (PII)	Add to Annex C — this is the largest gap
PDL / EnrichLayer / SerpAPI	(not listed)	sourcing pipeline	Add to Annex C if sourcing ships in v1
Azure STT	(not listed)	interview audio	Add to Annex C
BetterStack	(not listed)	heartbeats (no PII)	Optional — no PII, but disclosure is cleaner

Cross-border transfers: all of the above are US- or EU-based. Standard Contractual Clauses are the lawful basis for EU→US transfers; recheck the DPA Annex when adding a new sub-processor outside the EEA.

3. Data-flow diagram



Sourcing (optional, gated on env keys):

recruiter query → PDL / SerpAPI → EnrichLayer → candidates rows

Billing:

recruiter signup → Stripe Checkout → webhook → tenants / users

Observability:

pino logger (redacted) → stdout → container log aggregator

schedulers → BetterStack heartbeats (no PII)

4. Operational runbook — honoring a data-subject request

4.1 Right to access / portability (GDPR Art. 15 + Art. 20, CCPA “right to know”)

Candidate (self-service): they hit `GET /api/portal/me/export` from the portal. Returns a downloadable JSON with every row across the tables in §1.2 + §1.3 they’re the subject of, with `applications.notes` redacted (third-party data — released only after manual review by the DPO). An `audit_logs` row is written automatically. Returns `410 Gone` if the candidate has already exercised erasure.

Route is defined in `routes/career-profile.ts` and mounted via `routes/index.ts` (`router.use(careerProfileRouter)`), which is itself mounted at `/api` in `app.ts`. Net path: `/api/portal/me/export`.

Recruiter or admin-initiated: there is no recruiter-side data-export endpoint today (recruiters can already see all candidate data in-app). For an external regulator request on behalf of a candidate, use the same candidate endpoint via a one-time impersonation token issued by a platform admin. **Gap:** no UI for this yet — flag for follow-up.

4.2 Right to erasure (GDPR Art. 17, CCPA “right to delete”)

Candidate (self-service): `DELETE /api/portal/me` runs the anonymise-and-cascade transaction. Returns `{ ok: true, erasedRef }`.

Recruiter-initiated: `DELETE /api/dnc/:candidateId/data` (`routes/dnc.ts:215`). Same cascade.
Requires recruiter to be in the candidate's tenant.

Both paths:

1. Begin transaction.
2. Overwrite `candidates` PII columns with sentinel values; set `dataErasedAt = now()` , `dncReason = "gdpr_erasure" / "self_service_gdpr"` .
3. Cascade-delete or anonymise the adjacency tables (full list in `routes/dnc.ts:257–328`).
4. Commit. Best-effort `DeleteObject` for the S3 resume (orphans are acceptable and reaped by audit retry).
5. Write `[GDPR]` log line with the per-table purge summary.

The read side filters out `dataErasedAt IS NOT NULL` rows everywhere it matters (`candidates.ts:536/748` , `applications.ts:130`) so erased records never re-surface in lists, even though the row still exists for referential integrity.

4.3 Right to rectification (GDPR Art. 16)

`PATCH /api/portal/candidate/me` — candidate edits their own basic fields. Recruiters can edit via the candidate detail page. No special workflow.

4.4 Right to object / opt out (GDPR Art. 21, CCPA “right to opt out”)

`POST /api/dnc/:candidateId` flips `do_not_contact = true` . Suppresses all future outreach without erasing existing data. Recruiter UI surfaces this as “Add to DNC list”.

5. Incident-response checklist

If you suspect a PII leak (lost laptop, leaked credential, suspicious query, unauthorized export, etc.):

1. **Contain.** Rotate the affected credential immediately via the environment-secrets panel; revoke any active sessions (no shipped tooling for bulk session-revoke yet — flag in §7).
2. **Scope.** Pull `audit_logs` for the time window — `actor_id` , `action` , `subject_id` . Pull pino logs for the same window from the log aggregator.
3. **Notify.**
 - GDPR breach: 72 h to supervisory authority (`legal@l3xy.ai` to file).
 - CCPA breach: “expedient time and without unreasonable delay” — same day if it’s a clear breach.
 - Affected data subjects: GDPR requires direct notification if “high risk to rights and freedoms”; under CCPA, any California resident whose unencrypted PII was acquired by an unauthorized person.
4. **Document.** Append the incident to `SECURITY_NOTES.md` with what was accessed, the scope of subjects, the containment steps, and the notification timestamps.

6. What we *don't* erase, and why

- `audit_logs` — Art. 17(3)(b) carves out retention for legal claims and compliance. Audit rows reference the subject by ID but contain only the action taken, not screen-scraped PII fields. We need them to prove consent, prove timely response to DSR requests, and defend against fraudulent erasure claims.

- `communication_events` — record that an email was sent for spam-act compliance (CAN-SPAM, GDPR Art. 5(2) accountability). Body is retained because the law requires we can prove what was sent if challenged.
 - **applications row (after notes are scrubbed)** — kept so that hire / reject decisions remain auditable. Anonymised stage = “rejected”.
 - **Recruiter accounts (users)** — `passwordHash` and `email` are retained until the tenant deletes the account through support. A recruiter who self-deletes mid-investigation could destroy the actor side of audit evidence; bulk account deletion stays manual on purpose.
-

7. Known gaps (work for after launch)

- *Subject binding for /portal/ is email-based.** `getCandidateId(req)` (in `routes/career-profile.ts`) resolves the candidate by looking up `candidates.email = users.email`. If two candidate rows in different tenants share an email — which the schema permits — the lookup is ambiguous and could in principle expose the wrong subject’s data on `/portal/me`, `/portal/me/export`, and `friends`. In practice the candidate-account signup flow ties one user to one candidate row, so collisions are rare today, but this should be hardened to an explicit `users.candidate_id` FK before launch. **High priority.**
 - No DPIA on file — required for high-risk processing (AI-assisted candidate evaluation arguably qualifies). Draft one before the first enterprise deal.
 - No RoPA (Record of Processing Activities, GDPR Art. 30). The §1 / §2 tables above are 80% of one; promote them into a maintained spreadsheet.
 - DPA Annex C is materially out of sync with the actual sub-processor list — see §2.1 drift table. Update Annex C and republish before signing the first customer DPA.
 - No automated subject-access-request UI for recruiters acting on a candidate’s behalf — see §4.1.
 - No data-export endpoint for recruiters wanting their own account data. Lower priority — recruiters can already see everything in-app.
 - No session-revocation tooling beyond rotating individual creds — see §5.1.
 - No formal sub-processor change-notification list. Add an email list and wire it to deployment notifications when the §2 table changes.
 - Breach-notification SLAs are documented (§5) but not exercised — run a tabletop drill before signing the first regulated-industry customer.
 - `applications.notes` is auto-redacted from the export. There is no ticketing flow yet for the manual third-party-review release — for now it routes to dpo@l3xy.ai as a mailbox.
-

8. Change history

Date	Change	By
2026-05-16	Initial memo; added GET <code>/portal/me/export</code> (Art. 20)	hardening pass